Organizzazione e Sicurezza

Analisi del rischio

Dice il saggio cinese

Se conosci il nemico e conosci te stesso, non devi temere il risultato di cento battaglie.
Se conosci te stesso ma non il nemico, per ogni vittoria ottenuta potrai subire anche una sconfitta.
Se non conosci né il nemico né te stesso, soccomberai in ogni battaglia.

(Sun Zi Bing fa)

Analisi del rischio

Analisi del rischio per:

- Identificare beni, vulnerabilità e controlli
- Aumentare la consapevolezza
- Definire una base di conoscenza oggettiva per le decisioni
- Giustificare le spese per la sicurezza

L'analisi dei rischi è una pratica comune nel management, ma ogni sistema complesso ha proprie specificità e l'analisi deve essere adattata al particolare contesto esaminato.

Cosa è l'Analisi del Rischio

Misura del Rischio

Un metodo per quantificare l'impatto di un potenziale attacco ad un sistema

Il risultato finale dell'analisi del rischio:

- Aiuta a bilanciare rischi e costi
- Aiuta il management nella decisione di quali rischi prevenire, limitare o accettare

L'analisi e la gestione del rischio è prevista dal Information Security Management Process

PLAN

Define the scope of the ISMS- in

Define an ISMS policy - in termini di caratteristiche del business, della organizzazione, dei siti, degli asset e delle tecnologie che:

1) includa uno schema generale degli obiettivi dell'information security di alto livello
2) comprenda requisiti per responsabilità di business, di tipo legale e normativo, obbligazioni contrattuali
3) stabilisca le strategie organizzative ed il contesto di gestione del rischio in cui si cala la definizione e la gestione dell'ISMS
4) stabilisca i criteri con i quali valutare i rischi e definire la struttura del risk

Information security policy document

Il documento risponde alle domande:

- Perché la sicurezza è importante per l'impresa ?
- Ci sono particolari minacce o apprensioni avvertite dall'impresa?
- Cosa si vuole raggiungere in termini di confidenzialità, integrità e disponibilità sulle risorse(asset) di rilevanza per il business ?
- Quale livello di rischio si ritiene accettabile?
- Ci sono vincoli legali, contrattuali, normativi ?
- Ci sono scelte strategiche, di business tecnologiche o altro, verso le quali l'azienda si vuole muovere ?

Information security policy document
(ISO/IEC 17799)

3.1 Information security policy

Objective: To provide management direction and support for information security.

Decisione strategica rispetto a:

- cosa proteggere (indicazioni di massima)
- come gestire (indicazioni di massima)
- quanto spendere

3.1.1 Information security policy document

approvato dalla Direzione
pubblicato e diffuso a tutti i dipendenti
stabilisce il "mandato" e l'approccio per la gestione della "information security"

Information security policy document
(ISO/IEC 17799)

Contenuto minimo:

a) definizione della I.S., scopo ed obiettivi generali e l'importanza della sicurezza come meccanismo di condivisione delle informazioni

b) esposizione degli intenti della direzione a supporto degli obiettivi di sicurezza

c) una breve e chiara spiegazione delle politiche di sicurezza, principi, standard e requisiti di compatibilità di particolare rilievo, es.:

1) Compatibilità con requisiti contrattuali o di legge
2) Requisiti di formazione sulla sicurezza
3) Prevenzione e riconoscimento di virus;
4) business continuity
5) Conseguenze per violazioni di policy (es. Penali/ richiami, interruzione di contratto etc.);

d) Definizione di responsabilità generali o specifiche per la gestione dell'IS

e) Riferimenti a documenti di dettaglio a supporto della politica di sicurezza (ovvero <u>politiche e procedure di dettaglio</u> per specifici sistemi/sottosistemi, regole di comportamento degli utenti etc.) .

PLAN

Define a systematic approach to risk

Identify the risks

1)identifica gli asset ed i proprietari nell'ambito di

Assess the risks

1) Valuta il danno aziendale (business harm) che potrebbe derivare da incidenti di sicurezza a causa di perdita di confidenzialità, integrità e disponibilità

Identify and evaluate options for the treatment of risks-

Le possibili azioni sono:

1) applicare adeguati controlli
2) conoscere ed accettare oggettivamente I rischi, mostrando che soddisfano I criteri generali (policy) aziendali
3) evitare I rischi
4) trasferire I business risks ad altre parti (es. Assicurazioni o fornitori).

Definizioni

Vulnerabilità: punti deboli del sistema di sicurezza che può portare ad una perdita o ad un danno.
Attacco: azione effettuata da chi sfrutta una vulnerabilità
Minaccia: circostanze che possono causare perdite o danni al sistema o all'organizzazione; costituiscono minacce *attacchi* che possono essere effettuati dolosamente ma la possibilità di perdite accidentali per errori umani, guasti HW e SW
Asset/Risorsa: Componente o parte del Sistema Informativo (Hw, SW, Applicazioni, Data, Servizi)
Esposizione: possibile perdita o danno in un sistema informativo (es. perdita di dati, accesso non autorizzato ad informazioni..)
Impatto: L'effetto sull'Organizzazione della violazione della Sicurezza in termini di Integrità, Confidenzialità, Disponibilità, costituito dalla misura della perdita o del danno.

Risk Analysis & Management

Define a systematic approach to risk assessment

- Identificare un metodo di risk assessment adeguato agli obiettivi dell'ISMS:
  - Modello quantitativo
    - Valutazione economica del valore delle risorse e dei danni
    - Altre valutazioni non puramente economiche (es. mutuate su analisi costi/benefici)
  - Modello qualitativo
- Stabilire politiche e criteri per identificare livelli accettabili di rischio:
  - Di tipo generale(es: ridurre le perdite potenziali entro una certa soglia; accettare tutti i rischi con danno medio-basso)
  - O di tipo puntuale (per un certo insieme di dati evitarne la distruzione, ma accettare gli altri rischi)

Risk Analysis & Management

Risk identification and assessment

Contenuto minimo:

a) Identificare e classificare le risorse (*ISO/IEC 17799-5.1 Asset classification and control);*

b) Valutare le risorse, precisare la scala utilizzata, se non economica,

c) Identificare minacce e vulnerabilità potenziali;

d) Consolidare le minacce rispetto alle vulnerabilità effettive e valutare l'impatto che ne può derivare;

f) Valutare i rischi sulla base dei risultati del passo precedente, ed identificare i rischi residuali

Specificare l'approccio seguito e perché; se e come sono stati utilizzati eventuali tools, tecniche o metodologie.

Risk Analysis & Management

ISO/IEC 17799- 5.1 Asset classification and control

5.1.1 Inventory of asset

Each asset should be clearly identified and its ownership and security classification (see 5.2) agreed and documented, together with its current location (important when attempting to recover from loss or damage).

a) **information assets**: databases and data files, system documentation, user manuals, training material, operational or support procedures, continuity plans, fallback arrangements, archived information;

b) **software assets**: application software, system software, development tools and utilities;

c) **physical assets:** computer equipment (processors, monitors, laptops, modems), communications equipment (routers, PABXs, fax machines, answering machines), magnetic media (tapes and disks), other technical equipment (power supplies, airconditioning units), furniture, accommodation;

d) **services:** computing and communications services, general utilities, e.g. heating, lighting, power, air-conditioning.

Risk Analysis & Management

ISO/IEC 17799- 5.2 Information classification

To ensure that information assets receive an appropriate level of protection.

Information should be classified to indicate the need, priorities and degree of protection.
Information has varying degrees of sensitivity and criticality. Some items may require an additional level of protection or special handling.
An information classification system should be used to define an appropriate set of protection levels, and communicate the need for special handling measures.

Risk Analysis & Management

Risk treatment plan: Definisce le azioni per

- ridurre i rischi ad un livello accettabile
- implementare i controlli richiesti per proteggere le informazioni.

Per ogni rischio che sia ad un livello non accettabile, si deve stabilire se:

1) accettare il rischio, perché altre azioni sono impossibili o troppo costose
2) trasferire il rischio ad altre parti (es. assicurazioni o fornitori)
3) ridurre il rischio a livelli accettabili applicando ulteriori controlli.

Il piano deve specificare per ciascun rischio consolidato:

1. Il metodo di trattamento scelto (compresa l'accettazione);
2. I controlli esistenti;
3. I controlli addizionali proposti;
4. Il periodo entro cui i controlli proposti devono essere realizzati.

Risk Analysis ….

…non è un metodo scientifico,

Rischio: qualcosa o qualcuno che crea o favorisce un pericolo

Obiettivi dell'analisi del rischio

L'analisi del rischio consente di focalizzare gli obiettivi di sicurezza per rispondere al meglio agli obiettivi di business o alla missione dell'organizzazione.
La gestione del rischio ha lo scopo di supportare gli obiettivi relativi agli affari o alla missione dell'organizzazione.

L'analisi del rischio deve individuare le necessità di business dell'impresa e indirizzare la sicurezza per soddisfarle.

La sicurezza è una delle qualità richiesta dai processi di business: il ruolo della sicurezza è di aiutare a proteggere in modo adeguato le risorse dell'organizzazione in modo che l'organizzazione possa efficacemente svolgere le proprie attività raggiungere i propri scopi.

Obiettivi dell'analisi del rischio

Obiettivi emergenti, fonte Government Accounting Office- GAO 98-68, per imprese ed organizzazioni:

1. mantenere la fiducia dei clienti, azionisti o contribuenti dell'organizzazione
2. proteggere la confidenzialità delle informazioni sensibili(personali, finanziarie, secreti d'impresa..)
3. evitare la diffusione non autorizzata di dati gestionali sensibili
4. evitare la responsabilità di terze parti per atti lesivi commessi con sistemi dell'organizzazione
5. assicurare che computer, reti, applicazioni e dati dell'organizzazione non siano usati in modo inopportuno o danneggiati
6. evitare frodi
7. evitare incidenti costosi e distruttivi
8. soddisfare requisiti normativi
9. evitate un ambiente di lavoro ostile.

Obiettivi dell'Analisi del Rischio

L'analisi del rischio deve assicurare il bilanciamento tra obiettivi di business e la necessità di controlli adeguati.

Tempo e denaro spesi per mettere in sicurezza un asset deve essere coerente con il valore dell'asset e la stima delle perdite

- Non ha senso spendere risorse per proteggere beni di poco conto

La definizione dei controlli richiede la mediazione tra due mentalità estreme:

- mentalità della fortezza – nessuna fiducia
- campo aperto- completa fiducia

Analisi del rischio e Quality assurance

L'analisi del rischio, come parte integrante del processo di Quality Assurance, è un elemento chiave e va effettuata per ogni applicazione, sistema, progetto o processo che sta andando in produzione:

aggiungere controlli successivamente diventa notevolmente più costoso.

Il punto di partenza è identificare le informazioni come una risorsa dell'organizzazione.

Obiettivo della assicurazione della qualità (e della sicurezza) per le informazioni aziendali è la salvaguardia di:

- Integrità
- Disponibilità
- Confidenzialità.

Deve essere definito un processo di classificazione delle informazioni come parte integrante della gestione del rischio e del processo di assicurazione di qualità.

Analisi del rischio e Quality assurance

Definire il valore della risorsa informazione è complesso e può includere, alcuni, tutti o altri, aspetti:

- costo di produzione dell'informazione
- valore dell'informazione sul mercato
- benefici che l'informazione porta all'impresa nel raggiungere i propri obiettivi di affari di missione
- ripercussioni sull'impresa se l'informazione non è immediatamente disponibile
- vantaggio che potrebbe dare a un competitore se fosse diffusa, alterata o distrutta
- perdita di clienti o di fiducia se l'informazione non fosse protetta e trattata in modo sicuro
- perdita di credibilità se l'informazione non fosse sicura

Il valore delle risorse deve essere definito dal responsabile della *business unit* che utilizza (owner) la risorse; deve essere conosciuto dal responsabile della sicurezza e dei sistemi informativi.

I passi della Risk Analysis:

1. Identificare i beni
2. Determinare le vulnerabilità
3. Stimare la probabilità degli incidenti
4. Calcolare le perdite annuali
5. Definire i controlli ed i loro costi
6. Pianificare le azioni

I passi della Risk Analysis:

1. Identificare i beni

E' assimilabile al fare un inventario di beni che compongono il Sistema informatico di una organizzazione. I beni possono essere classificati in categorie omogenee:

Hardware: unità centrali, dischi, tastiere, monitor, terminali, memorie, pc, stampanti, unità nastro, cavi, controller, apparati di comunicazione, etc.

Software: programmi applicativi, sorgenti, eseguibili, utility, sistema operativo e programmi di sistema e di ambiente, diagnostici etc.

Dati: archivi e base dati, di configurazione, di esecuzione, file di log, di audit, di backup etc.

Risorse umane critiche: necessarie ad eseguire elaborazioni o specifici programmi

Documentazione: su applicazioni, hw, configurazione del sw di sistema, di ambiente e di rete, etc.

Materiale di consumo: carta, stampati, cartucce laser, inchiostri, supporti di memorizzazione, etc.

I passi della Risk Analysis:

1. Identificare i beni

Per ciascuna risorsa rilevare:

- Owner: responsabile della tenuta della risorsa (titolare e u.o.)
- Utenti/utilizzatori: tipologie di persone/u.o. che possono accedere alla risorsa e tipologie di operazioni che possono effettuare
- Requisiti di sicurezza: in termini di integrità, disponibilità, riservatezza
- Criticità: in termini di minacce/vulnerabilità
- Valore della risorsa: in termini economici e/o qualitativi
- Controlli e misure esistenti

La rilevazione va aggiornata ad ogni modifica significativa delle risorse o periodicamente.

I passi della Risk Analysis:

1. Identificare i beni

Se il sistema è complesso per individuare le risorse si può procedere con un approccio per sistemi/sottosistemi o per macro-processi/processi, a partire dai business process:

- Individuare i sistemi/sottosistemi corrispondenti ad aree di business (es sottosistema prestiti), stabilire cosa comprende nel dettaglio (es. applicazioni, dati, hw/sw di base e comunicazioni dedicato, pdl dedicati)
- Individuare sistemi/sottosistemi comuni (es. CED, rete, …) e stabilire cosa comprende nel dettaglio (componenti hw sw e di rete, pdl comuni, …)
- completare la rilevazione con una architettura di rete, di sistema e di applicazioni che diano il quadro di insieme ed evidenziano i mutui legami tra le diverse componenti.

In questo modo si ciascun sistema/sottosistema è assimilato ad una risorsa.

I passi della Risk Analysis:

2.Determinare le vulnerabilità

Immaginare quali danni possono avere le risorse e per quali cause.
Si parte dalle possibili minacce e si esamina quali sono gli effetti;
Ad esempio:

- errori non intenzionali (es. comandi errati, inserimento dati errati,..)
- attacchi di interni (impiegati scontenti, curiosi, ..)
- attacchi di esterni(accessi da rete o dial-in, hackers, persone di passaggio, ..)
- disastri naturali e fisici (fuoco, temporali, inondazioni, cadute di corrente, guasti di componenti del sistema

I passi della Risk Analysis:

2.Determinare le vulnerabilità

Una tavola riepilogativa può aiutare ad organizzare l'analisi delle possibili minacce.

Risorsa	Integrità	Disponibilità	Riservatezza

Tipi di minacce

Interruption una componente del sistema viene persa, è non disponibile o non usabile. *Es. la cancellazione di un programma o di un file, la distruzione di un apparato hw; ma anche il malfunzionamento del sistema operativo che non consente di riconoscere o di accedere ad un sistema di dischi*

Interception una parte (persona, un programma o un altro sistema) non autorizzata ha accesso ad una componente del sistema.
Es. ci può essere una copia non autorizzata di dati o di programmi, o l'intercettazione del traffico su rete.

Modification una parte non autorizzata, oltre ad accedere, modifica anche una componente del sistema. *Es. modifica i valori in una B.D., altera un programma o componenti hw.*

Fabrication costruzione di oggetti contraffatti. *Es. possono essere inserite transazioni spurie nella rete di comunicazione o aggiunti record in una banca dati.*

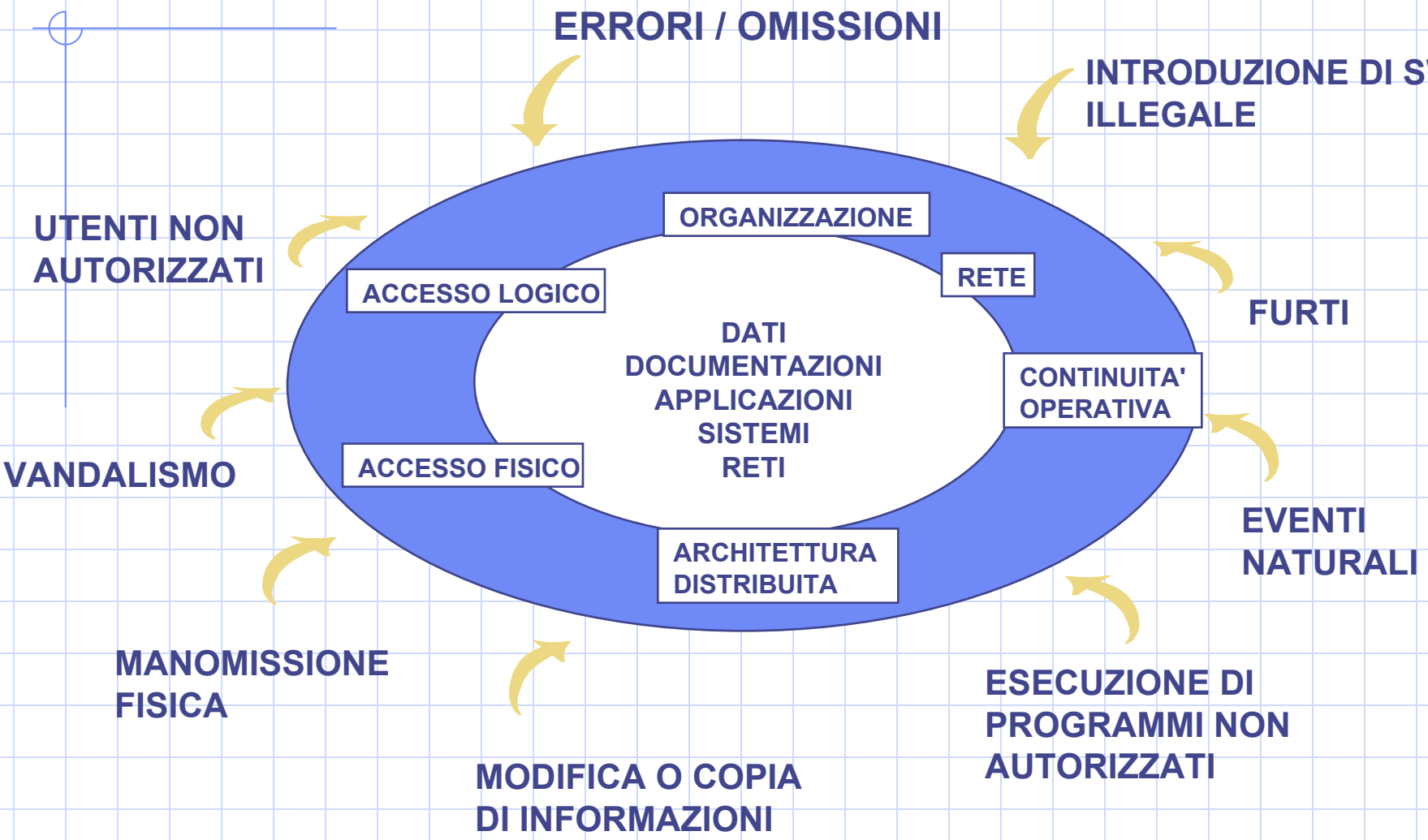
Vulnerabilità

- Applicando le possibili tipologie di minacce alle principali risorse si ha un quadro della vulnerabilità:

	Interruption	**Interception**	**Modification**	**Fabrication**
HW	***denial of service***	***theft***		
SW	***deletion***			
Dati	*loss*			

Patrimonio informativo aziendale e vulnerabilità

Le minacce


ERRORI / OMISSIONI
INTRODUZIONE DI SW ILLEGALE
UTENTI NON AUTORIZZATI
ORGANIZZAZIONE
RETE
ACCESSO LOGICO
FURTI
DATI
DOCUMENTAZIONI
APPLICAZIONI
SISTEMI
RETI
CONTINUITA' OPERATIVA
VANDALISMO
ACCESSO FISICO
EVENTI NATURALI
ARCHITETTURA DISTRIBUITA
MANOMISSIONE FISICA
ESECUZIONE DI PROGRAMMI NON AUTORIZZATI
MODIFICA O COPIA DI INFORMAZIONI

I passi della Risk Analysis:

2.Determinare le vulnerabilità

Risorsa	Riservatezza	Integrità	Disponibilità
Harware		Sovraccarico Distrutto Alterato	Rubato Distrutto Fuori uso
Software	Rubato Copiato Piratato	Trojan horse Modificato Alterato	Cancellato Memorizzato male Licenza scaduta
Dati	Rilevati Acceduti da esterni Interpretati	Danneggiati: Sw error Hw error User error	Cancellati Memorizzati male Distrutti
Risorse umane			Dimesse/licenziate In pensione Fine contratto In vacanza
Documentazione	Copiata Diffusa senza autorizzazione	Danneggiata Alterata	persa rubata distrutta
Materiali di consumo			persi Rubati distrutti

I passi della Risk Analysis:

3.Stimare la probabilità degli incidenti

Stabilire con quale probabilità ciascuna esposizione potrà presentarsi, con gli attuali controlli di sicurezza.

Vi sono diversi metodi di stima della probabilità:

- osservazione di un campione generale ☾ le compagnie di assicurazioni dai dati a loro disposizione sono in grado di valutare che in un anno vi saranno incendi su *n* case con una perdita media economica di *x* €. Dati simili sono disponibili su altri disastri naturali e furto. I produttori hanno statistiche sulla vita attesa dei macchinari, come pure si trovano dati di letteratura sull'incidenza di errori umani divario tipo.
- osservazione di dati registrati di uno specifico sistema: ad esempio le cadute di sistema e di singoli componenti, i tentativi di login falliti e simili, sono facili da memorizzare ed analizzare,

I passi della Risk Analysis:

3.Stimare la probabilità degli incidenti

Altrimenti ci si può basare sulla stima:

- del numero di occorrenze in un dato periodo per un dato evento. In questo caso la probabilità deriva da stime effettuate a posteriori sulla base dell'esperienza e della memoria.
- di percentuali tipo, riportate in una tabella, che guida a pesare l'incidenza di un dato evento. È un affinamento del metodo precedente.

Frequenza	Peso
Più di una volta al giorno	10
Una volta al giorno	9
Ogni tre giorni	8
Ogni settimana	7
Ogni due settimane	6
Ogni mese	5
Ogni 4 mesi	4
Ogni anno	3
Ogni tre anni	2
Meno di una volte in tre anni	1

I passi della Risk Analysis:

3.Stimare la probabilità degli incidenti

- **Metodologia Delphi**- si raccolgono le stime di probabilità che un dato evento si verifichi (o che si è verificato) date da differenti persone. Le stime sono raccolte e ridistribuite tra chi ha fatto la prima stima per un giro di revisione, dove a ciascuno viene chiesto di confermare o modificare la stima originaria. Se i valori sono ragionevolmente consistenti (dispersione accettabile entro un certo range) viene ricavato il valore stimato finale.

I passi della Risk Analysis:

4.Calcolare le perdite annuali

- Calcolare il costo atteso dei danni conseguenti ciascun incidente. Stabilito il costo del possibile danno di un incidente si moltiplica per il numero atteso di incidenti in un anno e si ottiene il valore Annual Loss Expectancy(ALE).

Una analisi accurata dei possibili danni, anche se non porta alla completa definizione dei costi, consente di individuare le fonti di costi tangibili e intangibili

I passi della Risk Analysis:

4.Calcolare le perdite annuali

Alcuni costi, come quelli per ripristinare o sostituire apparati hw, sono piuttosto semplici da individuare(costo d'acquisto o residuo non ammortizzato, oltre ai costi accessori di installazione/configurazione).
Analogamente per le componenti sw il il costo è tipicamente quello di ripristino. Sia per hw e sw i costi di ripristino sono tanto più contenuti quanto più accurata è la gestione delle configurazioni.

I problemi maggiori riguardano i dati. Si può fare riferimento al costo iniziale di acquisizione(ad esempio se devono essere riacquisiti o ricostruiti) o al costo del loro ripristino (se si hanno backup aggiornati), ma ciò non esaurisce le problematiche.

I passi della Risk Analysis:

4.Calcolare le perdite annuali

- Alcuni dati devono essere protetti per questioni legali: es dati personali sensibili (come dati di polizia, sanitari, tasse, redditi) sono protetti da normativa e ci possono essere implicazioni anche penali
- Alcuni dati finanziari possono avere seri effetti sui crediti bancari, compagnie di assicurazioni, creditori ed altro
- Altre sono informazioni aziendali confidenziali: dati di un nuovo prodotto, la lista dei clienti, informazioni finanziarie
- L' indisponibilità di risorse (dati, sw, hw o umane) che causa la ritardata esecuzione di un particolare lavoro può avere conseguenze economiche dirette (minori incassi o pagamento di penali) o indirette(es. perdita di clienti).
- Per taluni sistemi, infine, una caduta di servizio può portare a costi in vite umane (es. sistemi di controllo traffico aereo o ferroviario; sistemi ospedalieri).

I passi della Risk Analysis:

4.Calcolare le perdite annuali

Una possibile check-list:

- vi sono obblighi legali per preservare la confidenzialità e l'integrità di determinati dati
- la diffusione di determinati dati può: causare un danno materiale a delle persone o ad una organizzazione o giustificare azioni legali da parte dei danneggiati
- L'accesso non autorizzato ad alcuni dati può: causare la perdita di opportunità di futuri affari; dare un vantaggio ad un competitore; portare ad una perdita delle vendite
- Ci può essere un impatto psicologico a seguito di un incidente di sicurezza: imbarazzo dei clienti/utenti; perdita di credibilità; perdita di affari; (pesare in base a quanti clienti sono coinvolti ed il loro peso, come volume di affari)
- Il valore degli accessi ai dati o dei servizi: può essere ritardato o differito; il servizio può essere erogato da altre parti; in tal caso quanto costa;
- Quale è il valore dei dati o dei servizi che un competitore sarebbe disposto a pagare
- Quali problemi possono derivare dalla perdita dei dati: possono essere recuperati, ricostruiti o ricaricati; quanto lavoro, quanto tempo e quali costi richiede.

I passi della Risk Analysis:

5.Definire i controlli applicabili ed i loro costj

- A seguito dei risultati del passo precedente si può decidere di intervenire nelle aree con maggiore ALE. Si può procedere con due modalità:

a) identificare le misure possibili per ciascuna esposizione e valutarne l'efficacia/costi (es. per la perdita di dati le misure possibili sono: backup periodici, memoria dati ridondante, controllo accessi per evitare cancellazioni o alterazioni, sicurezza fisica per evitare danneggiamenti ai dischi, o altro);

b) definire una architettura di sicurezza generale, coerente con le politiche: stabilire come distribuire i controlli, stante la loro ridondanza, tra livelli fisico, hw, sw applicativo, apparati di rete, protocolli, ed organizzativo, considerare l'insieme delle misure esistenti, l'insieme delle misure possibili e selezionare i controlli che coprono specifiche esposizioni residue; valutare efficacia/ costi dell'insieme.

I passi della Risk Analysis:

6.Pianificare le azioni

Il costo effettivo della sicurezza è il costo delle misure adottate o da adottare al netto delle perdite annuali attese.

Sulla base del costo effettivo si può decidere, salvo valutazioni non economiche, in modo abbastanza oggettivo l'opportunità dell'insieme di misure da adottare.

Diversi metodi di analisi dei rischi

Vi sono molti metodi di analisi dei rischi, automatizzati e non.
Possono essere suddivisi in due grandi categorie:

- Analisi del rischio quantitativa
- Analisi del rischio qualitativa

Analisi quantitativa

Cerca di assegnare un valore numerico obiettivo (tipicamente valore monetario) alle componenti ed ai livelli di perdite potenziali.

Quando tutti gli elementi sono valorizzati (valore degli asset, frequenza delle minacce, efficacia della sicurezza, costi della sicurezza, incertezze e probabilità) il processo è considerato completamente quantitativo.

es. Annual Loss Expectancy (ALE)

Analisi quantitativa

Annual Loss Expectancy(ALE)

Esempio

Risorsa = Data Server
Minaccia = Instabilità elettrica
Costo/incidente = € 2.000
Frequenza = 2 volte in 1 anno

==> **ALE = € 2.000 x 2 = €4.000**

Risk Analysis "Quantitativa":
La valutazione quantitativa: ALE

	Risorsa1	Risorsa2	Risorsa3	Risorsa4	etc	TOTALE
Threat1	ALE11	ALE12	ALE13	etc		ALEt1
Threat2	ALE21	ALE22	ALE23			ALEt2
Threat3	etc					
TOTALE	ALEa1	ALEa2				ALE

Analisi quantitativa

Aspetti positivi:

- risultati basati su processi e metriche indipendenti ed obiettive
- grande impegno nella valutazione degli asset e nella riduzione dei rischi
- è la base per una valutazione di costi/benefici
- i risultati possono essere espressi in linguaggio pienamente comprensibile dalla direzione (valori monetari, percentuali e probabilità)

Aspetti negativi

- calcoli complessi
- dati storici sono possibili solo se associati a tool di rilevazione automatici e se sono associati ad una base di conoscenza
- è richiesto un grande lavoro preliminare
- Difficoltà a valutare danni su risorse intangibili (es. fiducia dei clienti, immagine etc.)
- è poco flessibile

Analisi quantitativa

Questo tipo di metodologie hanno problemi associati alla inaffidabilità ed alla bassa accuratezza dei dati:

- la probabilità non sempre è precisa,
- controlli e contromisure impattano su diversi eventi potenziali e gli eventi stessi sono spesso correlati

Piccoli singoli errori di stima possono portare a risultati inaffidabili, su analisi estese

Spesso sono poco bilanciate le valutazioni tra minacce di ampio impatto ma poco frequenti (es. incendi), rispetto a minacce di piccolo impatto ma molto frequenti (es. cattivo uso delle risorse).

Risk Analysis “Qualitativa”

In questi metodi non si assegnano valori numerici alle singole componenti, ma si utilizzano scale qualitative per la valutazione di risorse, minacce, vulnerabilità, rischi

1 - 10

Basso, Medio, Alto

Conveniente, Utile, Importante, Critico, Vitale

Sono analisi di scenario e rispondono a domande di tipo “what if”. Sono metodi di natura soggettiva.

Analisi qualitativa

Aspetti positivi

- non è necessario calcolare il valore monetario degli asset
- non è necessario determinare la frequenza degli incidenti
- è semplice coinvolgere staff non tecnici e don di sicurezza
- Meno Labour Intensive e Time Consuming
- flessibile nel processo e nei report
- Consente una valutazione anche dei beni intangibili di impatti non economici

Aspetti negativi

- processo per natura soggettivo
- i risultati dipendono dalla “qualità” del team che svolge l’analisi del rischio
- non costituisce la base per una valutazione costi/benefici
- Con uno sforzo limitato si può stabilire il valore monetario per gli asset strategici

Risk Analysis "Qualitativa"
La valutazione

- **Matrice di correlazione tra:**
  - livello della minaccia (VL, L, M, H, VH)
  - livello delle vulnerabilità (L, M, H)
  - Valore della risorsa (1-10)

IMPATTO: misura del rischio (1-7)
esplicitato per ogni risorsa o per i business process, nel suo complesso, in relazione alle conseguenze (in termini di violazione di integrità, riservatezza e disponibilità) correlate alle minacce

Matrice del Rischio : Qualitativa

Minaccia à		Very Low			Low			...Very High
Vulnerabilità à		L	M	H	L	M	H	...H
Risorsa	1	1	1	1	1	1	1	3
	2	1	1	2	1	2	2	4
	3	1	2	2	2	2	3	4
	4	2	2	3	2	3	3	5
	5	2	3	3	3	3	4	5
	... 10	5	5	6	5	6	6	7

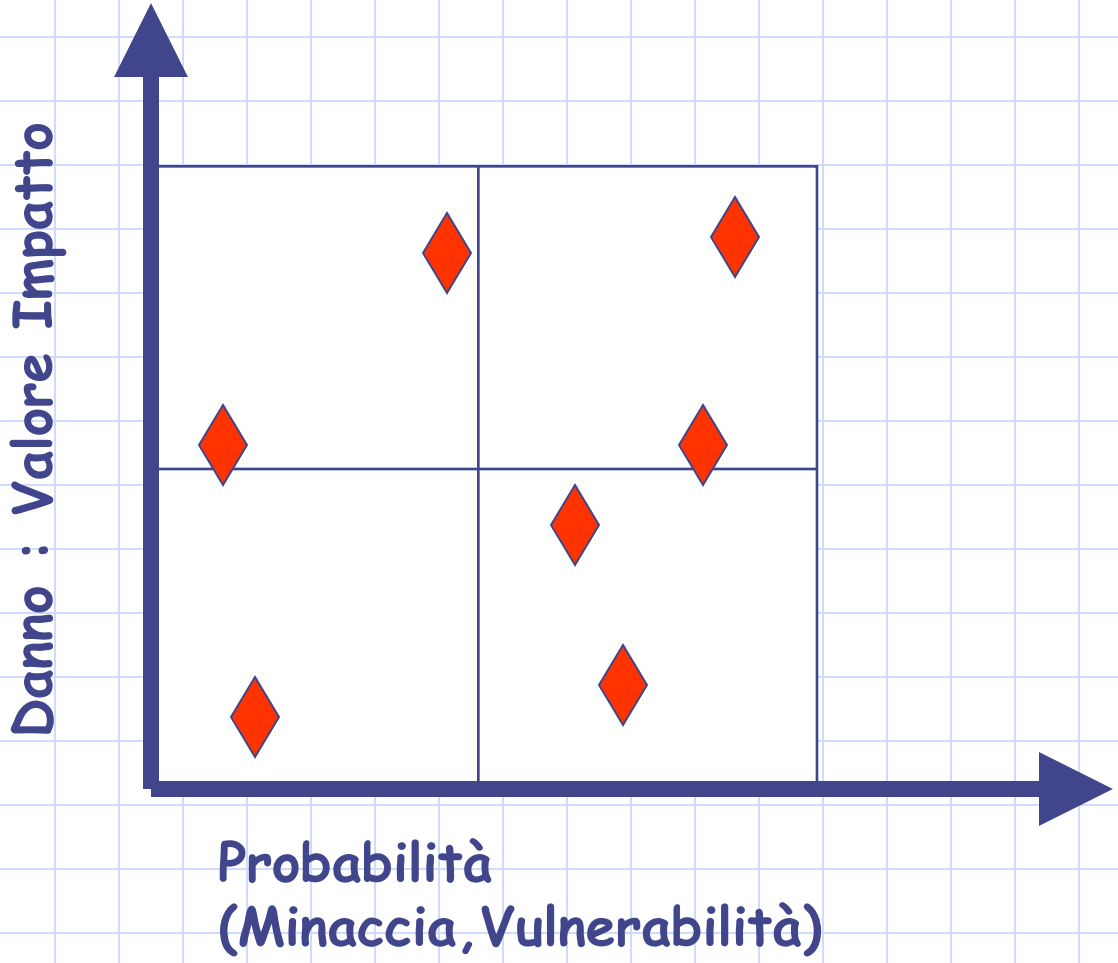
Esempio valutazione qualitativa

Risorsa: Gestione conti correnti (Business Process) --> 7
Minaccia: Mascheramento dell'identità di un utente------> **High**
Vulnerabilità: Violazione riservatezza-
Divulgazione non autorizzata dei dati ---------
->**Medium**

Matrice di correlazione, in funzione di M,V,A

Misura del Rischio: 5

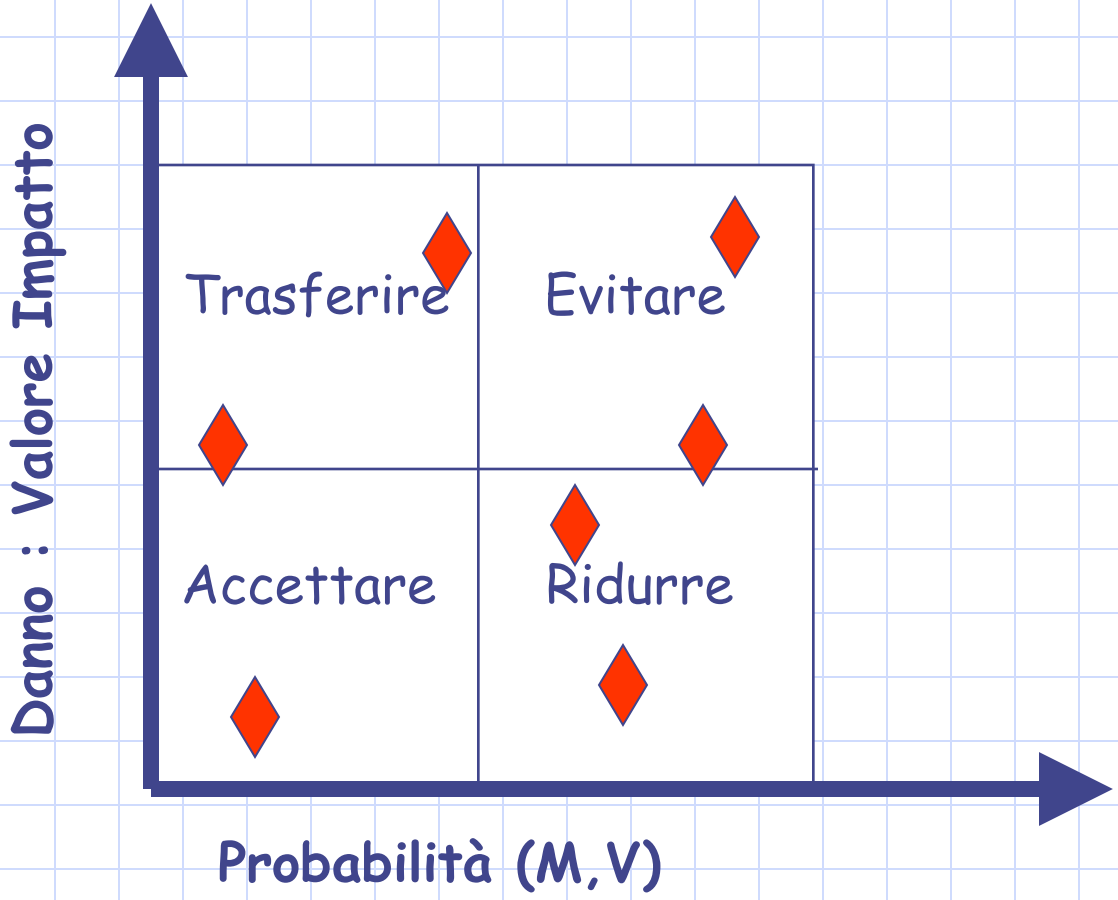
Misurare i Rischi



Risk Management : la strategia

- Evitare
- Accettare
- Trasferire
- Ridurre:
  - le Minacce,
  - la Vulnerabilità,
  - l'Impatto

Gestire il Rischio



Ridurre il rischio: Contromisure

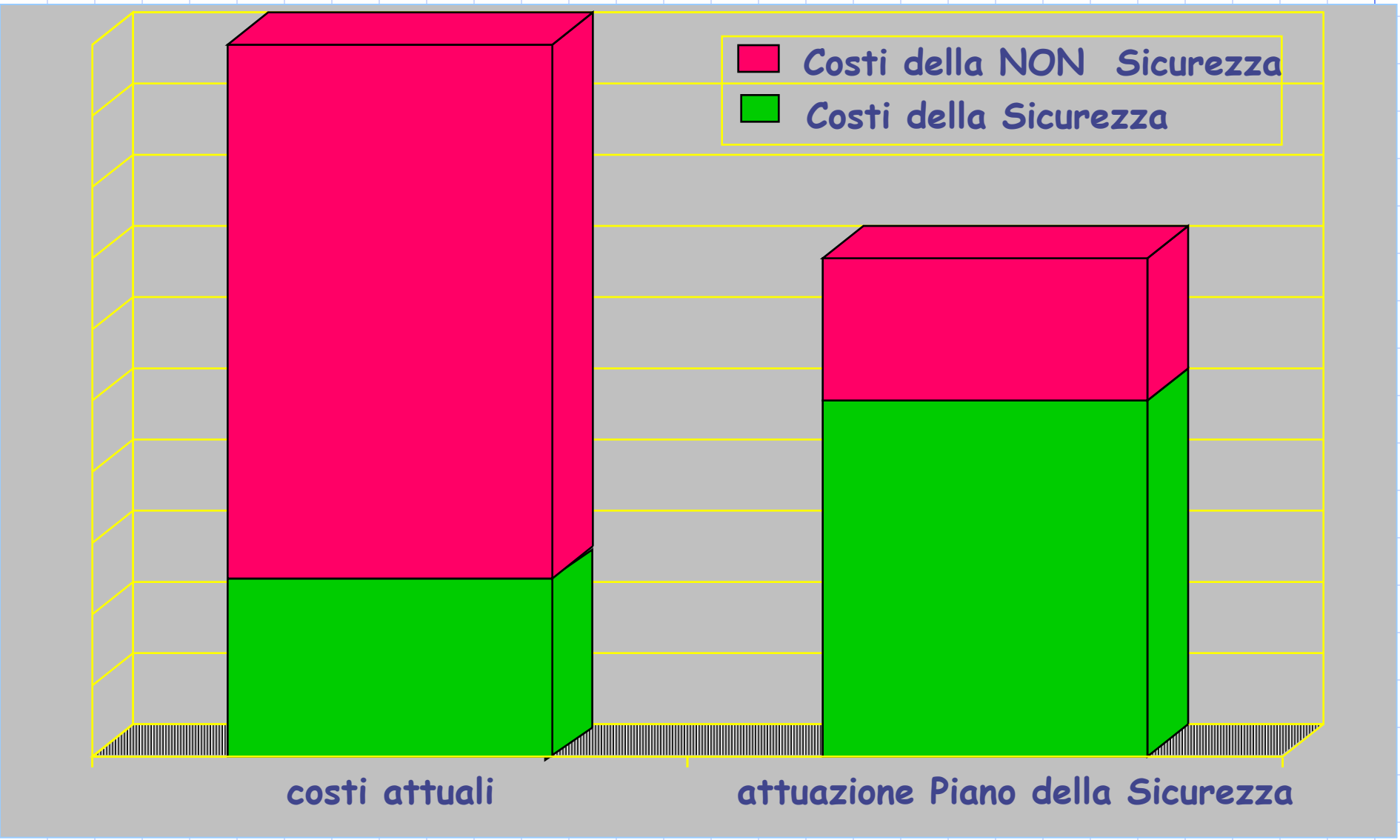
- Fisiche
- Procedurali
- Personale
- Tecniche (HW e SW)

Risk Management
La selezione delle contromisure

La selezione delle contromisure e' il risultato del processo ciclico di analisi e gestione del rischio che si esplica attraverso:

- l'analisi delle minacce (analisi delle varie modalità di violazione delle autorizzazioni)
- l'assegnazione di un parametro di gravità a ciascuna minaccia che esprima il rischio connesso con l'avverarsi della minaccia stessa
- la riduzione del rischio, mediante la scelta di opportune contromisure, fino ad un valore considerato accettabile
- l'individuazione e la gestione del rischio residuo

RISK MANGEMENT : APPROCCIO COST-EFFECTIVE

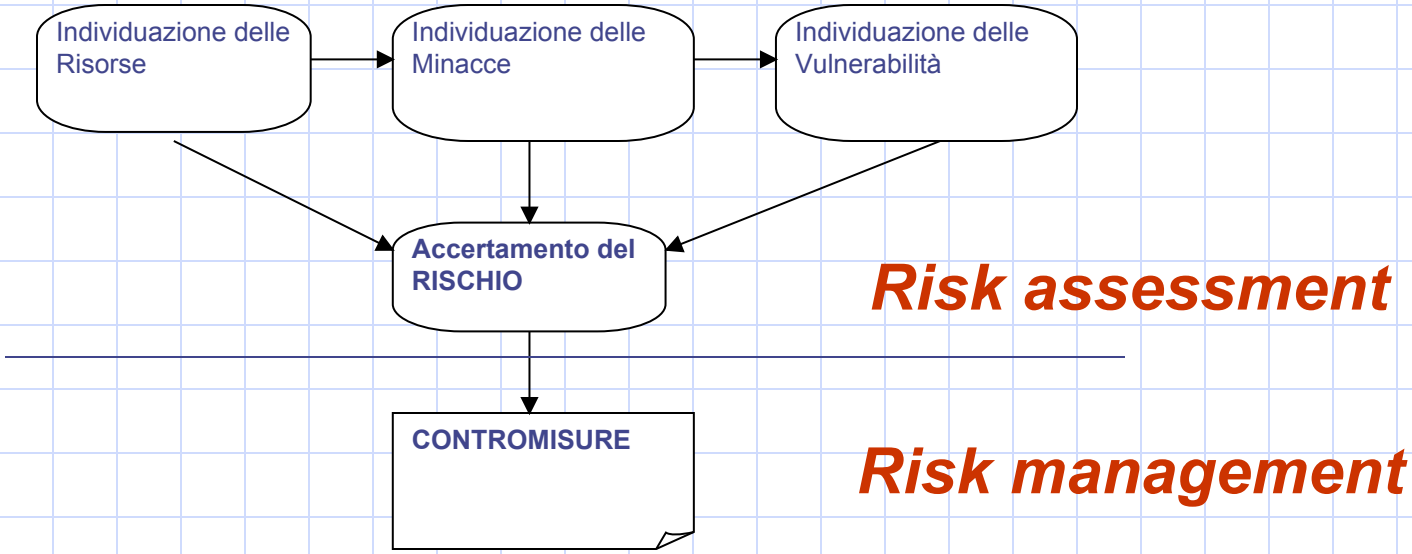


Caratteristiche delle metodologie di Risk Analysis & Management

- Quantitativa/ Qualitativa/…
- Risk Analysis / & Management
- Orientamento: minacce / vulnerabilità/ impatti/ rischi
- Enfasi contromisure - fisiche/ procedurali/ personale/ tecniche
- Supporto tool
- Facilità di utilizzo
- Expertise richiesta

Accertamento del rischio-
Raccolta dati ed Analisi

Si parte dalla individuazione delle risorse critiche (hardware, software, dati sensibili…), quindi si elencano le possibili vulnerabilità delle risorse e le conseguenti minacce che possono danneggiarle.



Analisi del rischio- Definizioni ISO 17799

Risk assessment

*Assessment of **threats** to, **impacts** on and **vulnerabilities** of information and information processing facilities and the **likelihood of their occurrence**.*

Risk management

*Process of identifying, controlling and **minimizing or eliminating security risks** that may affect information systems, **for an acceptable cost**.*

Accertamento del rischio-
Raccolta dati ed Analisi

1. Individuazione delle risorse

Le risorse rilevanti vengono individuate e classificate in categorie:

- risorse IT (hardware, software ed informazioni),
- risorse relative al personale (consulenti esterni, personale conto terzi, staff),
- risorse ambientali (edifici, facilities)

Successivamente si valutano i requisiti di sicurezza delle risorse, in termini di riservatezza, integrità e disponibilità.

Accertamento del rischio-
Raccolta dati ed Analisi

1.Individuazione delle risorse

Esempi di risorse possono essere:

- *Informazioni*: database e file di dati, documentazione di sistema, manuali per gli utenti, materiale di training, procedure di supporto o operative.
- *Documenti cartacei*: contratti, linee guida, documentazione dell'organizzazione, documenti con importanti risultati commerciali.
- *Risorse software*: applicazioni software, sistemi software, tools di sviluppo, utilities.
- *Risorse fisiche*: computers, attrezzature per la comunicazione, supporti di memorizzazione, attrezzature tecniche, forniture di vario genere.
- *Personale, clienti, utenti.*
- *Servizi*: servizi di comunicazione,servizi di outsourcing.

Accertamento del rischio-
Raccolta dati ed Analisi

1.a Individuazione del valore d'impatto delle risorse

Per definire il valore d'impatto la risorsa deve essere considerata in riferimento all'integrità, alla disponibilità e alla riservatezza:

- Integrità: ridurre a livelli accettabili il rischio di cancellazioni o modifiche delle informazioni, a seguito di interventi da parte di entità non autorizzate oppure a causa di fenomeni non controllabili.
- Disponibilità: ridurre a livelli accettabili il rischio che le entità autorizzate, non abbiano l.accesso alle informazioni, in seguito ad interventi da parte di entità non autorizzate o dal verificarsi di fenomeni non controllabili.
- Riservatezza: ridurre a livelli accettabili il rischio che un'entità possa, volontariamente o involontariamente, accedere alle informazioni senza essere autorizzata.

Accertamento del rischio-
Raccolta dati ed Analisi

1.a Individuazione del valore d'impatto delle risorse

1.a.1 Integrità - I responsabili della sicurezza devono tutelare l'integrità dei loro dati, così da mantenerne inalterata la loro completezza e la loro accuratezza. Non tutti i dati richiedono uno stesso grado di integrità, in quanto non tutte le informazioni hanno la stessa importanza per l'azienda.
Un esempio di classificazione dei requisiti di integrità:

Requisiti integrità-Qualitativi	Quantitativi
Bassa	1-3
Moderata	4-7
Alta	8-9
Assoluta	10

Accertamento del rischio-
Raccolta dati ed Analisi

1.a Individuazione del valore d'impatto delle risorse

1.a.2 Riservatezza - Salvaguardare la riservatezza significa proteggere le informazioni da scoperte e divulgazioni non autorizzate da parte di entità esterne.

Requisiti Riservatezza- Qualitativi	Quantitativi
Dati Pubblici: non è richiesta nessuna riservatezza	0
Dati non contrassegnati: informazioni che non sono critiche ma nemmeno pubbliche	1-3
Dati Confidenziali: informazioni la cui conoscenza non causa danni irreparabili in quanto non riguardano dati sensibili	4-5
Dati Protetti: la diffusione, la perdita, l'alterazione o la compromissione causa danni considerevoli	6-7
Dati sensibili: la diffusione, la perdita, l'alterazione o la compromissione comporta danni rilevanti all'azienda, ai propri clienti e alle persone coinvolte	8-10

Accertamento del rischio-
Raccolta dati ed Analisi

1.a Individuazione del valore d'impatto delle risorse

1.a.3 Disponibilità - E' riferita alla capacità di rendere accessibili le informazioni secondo le esigenze, anche dopo che siano state distrutte, intenzionalmente o accidentalmente.

Requisiti Disponibilità- Qualitativi	Quantitativi
Bassa: dati irrilevanti per le attività aziendali	1-3
Moderata: l'indisponibilità dei dati ha impatto sull'attività aziendale, il recupero delle informazioni deve essere fatto entro pochi giorni	4-6
Alta- l'indisponibilità causa ingenti danni e le informazioni devono essere recuperate entro poche ore	7-8
Molto alta: informazioni vitali per lo svolgimento delle attività aziendali, da recuperate entro pochi minuti	9
Altissima: non è tollerata la perdita, i dati devono essere sempre disponibili per il corretto funzionamento dell'azienda, il recupero deve essere immediato	10

Accertamento del rischio-
Raccolta dati ed Analisi

1.b Classificazione delle minacce

Le minacce possono essere accidentali o intenzionali, esterne o interne. In ogni caso, possono causare la perdita di integrità, disponibilità e riservatezza. I danni causati dalle minacce riguardano la scoperta,la copia, la distruzione, la modifica, l'alterazione, l'indisponibilità o la perdita di informazioni.

Accertamento del rischio-

Classificazione delle minacce

Sicurezza fisica e ambientale

- **Sicurezza settoriale**: ha l'obiettivo di prevenire gli accessi non autorizzati, i danni e le interferenze ai servizi IT.
  Possibili minacce: terremoti, incendi, allagamenti, furti, azioni industriali, danni volontari, intrusioni.
- **Sicurezza delle attrezzature**: ha lo scopo di prevenire perdite, danni o compromissioni delle risorse ed interruzioni delle attività aziendali.
  Possibili minacce:
  - Mancanza di fornitura elettrica,
  - incendi, allagamenti,
  - guasti dell'hardware oppure errori
  - errati interventi di manutenzione,
  - virus, Trojan Horses, backdoor,
  - accessi via rete da parte di utenti non autorizzati,
  - furti,
  - errori degli utenti.

Accertamento del rischio-

Classificazione delle minacce

Sicurezza della rete

Ha l'obiettivo di assicurare la correttezza e la sicurezza operativa dei servizi di rete. Possibili minacce

- incendi, allagamenti
- furti,
- fallimenti del software,
- errori di manutenzione,
- software malizioso (virus),
- errori del personale,
- insufficienza di potenza elettrica, instabilità dell'alimentazione
- infiltrazioni nella comunicazione,
- accessi non autorizzati al network,
- occultamenti riguardanti l'effettiva identità dell'utente,
- misrouting oppure rerouting dei messaggi,
- uso improprio delle risorse,
- sovraccarico del traffico,
- errori di trasmissione,
- uso del software da parte di utenti non autorizzati o con modalità non autorizzate.

Accertamento del rischio-

Classificazione delle minacce

Aderenza

riguarda la rispondenza ai requisiti legali, le revisioni relative alla sicurezza dei sistemi e le operazioni di audit

- **Requisiti legali**: per essere tutelati legalmente è necessario rispettare alcune regole generali relative sia a policy di sicurezza, sia ad indicazioni di tipo legale.
  Possibili minacce:
  - infiltrazioni nella comunicazione,
  - importazione/esportazione illegale di software,
  - uso illegale di software,
  - occultamento dell'identità dell'utente,
  - uso improprio delle risorse,
  - accessi non autorizzati al network,
  - uso del software con modalità non autorizzate.

Accertamento del rischio-

Classificazione delle minacce

Aderenza

- **Revisioni di sicurezza:** hanno lo scopo di revisionare il sistema per renderlo adeguato alle policy di sicurezza e agli standard. Eventuali minacce che possono verificarsi durante questa attività sono:
  - mancanza di comunicazione,
  - importazione/esportazione illegale del software,
  - uso illegale del software,
  - software malizioso,
  - occultamento dell'identità dell'utente,
  - uso improprio delle risorse,
  - accesso al network da parte di utenti non autorizzati,
  - uso del software con modalità non autorizzate.

Accertamento del rischio-

Classificazione delle minacce

Aderenza

- **Operazioni di audit**: sono dei controlli realizzati per salvaguardare le operazioni di sistema e i tool di audit durante le operazioni di controllo. Possibili minacce sono:
  - infiltrazioni nella comunicazione,
  - mancanza di comunicazione,
  - uso illegale del software,
  - software malizioso,
  - occultamento dell'identità dell'utente,
  - uso improprio delle risorse,
  - accesso al network da parte di utenti non autorizzati,
  - furto,
  - uso del software da parte di utenti non autorizzati, uso del software con modalità non autorizzate

Accertamento del rischio-
Raccolta dati ed Analisi

1.c Classificazione delle vulnerabilità

La vulnerabilità in se non costituisce fonte di danni, se non c'è una minaccia che la sfrutta. Una vulnerabilità che non ha una corrispondente minaccia, non richiede nessuna contromisura necessaria a neutralizzarla. Le vulnerabilità sono strettamente legate alle caratteristiche intrinseche e alle proprietà delle risorse.

Accertamento del rischio-

Classificazione delle vulnerabilità

Anche le vulnerabilità possono essere suddivise in categorie. Le principali riguardano: sicurezza del personale, sicurezza fisica ed ambientale, management dei computer e del network e mantenimento e sviluppo dei sistemi per il controllo degli accessi.

Sicurezza del personale

- Mancata presenza di personale
- Assenza di controlli sul lavoro da parte di audit
- Scarsa documentazione del software
- Insufficienza dei meccanismi di controllo interni
- Insufficienza delle policy per il corretto uso dei mezzi di comunicazione
- Insufficiente istruzione
- Procedure di assunzione inadeguate

Sicurezza fisica ed ambientale

- Insufficienza di protezioni per l.accesso all.edificio
- Inadeguatezza dei controlli fisici per l'accesso agli uffici, ai laboratori
- Supporti per la memorizzazione non protetti da agenti magnetici
- Suscettibilità delle attrezzature agli agenti atmosferici
- Suscettibilità delle attrezzature ai cambiamenti di potenza elettrica

Accertamento del rischio-
Classificazione delle vulnerabilità

Management computer e network

- Linee di comunicazioni non protette
- Cablaggio inadeguato
- Mancanza di sistemi di autenticazione ed identificazione
- Trasmissione delle password in chiaro
- Insufficienti garanzie nelle spedizioni/ricezioni dei messaggi
- Accessi non controllati con linee dial-up
- Traffico riservato non protetto
- Connessioni a network pubblici senza protezione

Sistemi per il controllo degli accessi

- Interfacce utente complesse e/o non univoche
- Scarsità di audit-trails
- Scarsità di istruzione e controllo
- Mancanza di logoff quando si lascia la workstation
- Test sul software insufficienti o nulli
- Uso e dowloading del software non controllato
- Management insufficiente delle password
- Tabelle delle password non protette
- Errata allocazione degli accessi

Accertamento del rischio-

Valutazione della vulnerabilità in rapporto ad una minaccia

La presenza di una vulnerabilità va valutata rispetto alla probabilità che una data minaccia possa sfruttarla (altamente probabile, probabile, possibile..) il cui valore qualitativo può essere associato ad valore numerico convenzionale

Stima Vulnerabilità qualitativa	Stima quantitativa
Impossibile	0
Improbabile	1-3
Possibile	4-6
Probabile	7-8
Altamente probabile	9-10

Accertamento del rischio-
Valutazione del rischio

2 Valutazione del rischio

Attraverso una matrice di correlazione (Impatto,Minacce,Vulnerabilità), si può avere una valutazione quali/quantitativa del rischio.

Nella matrice si elencano le risorse con possibili minacce (rispetto alla integrità, disponibilità e confidenzialità) e si riporta il corrispondente valore numerico dell'impatto e della vulnerabilità. Il rischio viene calcolato il rischio come
Rischio = Impatto x Vulnerabilità

Accertamento del rischio-
Valutazione del rischio

Accertamento del rischio-
Esempio

Risorsa: in una casa l'argenteria e i quadri di valore sono segnalati come beni da proteggere perché non possono essere messi in cassaforte.

Valore di Impatto: In una scala da 0 a 10 il valore presunto assegnato agli oggetti contenuti nella casa è 8.

Minaccia: Furto

Vulnerabilità: la *vulnerabilità* è legata alla *minaccia* di furto sulla *risorsa* casa. Essa dipende da quanti punti di accesso possibili esistono, visto che le porte e le finestre in una casa sono *vulnerabilità intrinseche* rispetto ai furti. Per valutare la *vulnerabilità,* come probabilità che la casa possa subire un furto, si considera:

- Dove si trova la casa (in un quartiere popoloso, in aperta campagna; in un luogo poco illuminato di notte, etc.)
- Quanti furti ci sono stati nel quartiere nell'ultimo periodo;
- Di quali porte/finestre è attualmente dotata la casa

Da tale analisi si deduce che l'evenienza di un furto, nella situazione attuale, sia *Probabile*, si stima quindi una vulnerabilità 8.

Rischio: Il valore del rischio è dato dal *Valore di Impatto x la Vulnerabilità*.

Nel nostro caso abbiamo un **Rischio = 8*8=64**

Accertamento del rischio-
Esempio

Le proposte per limitare il rischio sono:

Contromisura 1: installare porte e finestre blindate, la minaccia di furto diventa *improbabile*, Vulnerabilità = 2

Contromisura 2: applicare catenacci a porte e finestre non blindate, la minaccia di furto diventa *possibile, Vulnerabilità = 5*.

	Contromisura attuale	Contromisura 1	Contromisura 2
Vulnerabilità	8	2	5
Valore di impatto	8	8	8
Rischio	64	16	40